

CYNA DEV

Rapport de Test

Module Authentification

Projet : CYNA DEV

Périmètre : Inscription, confirmation e-mail, connexion, mot de passe oublié, rate-limiting, contrôle d'accès par rôle

Résultat global : 16/16 tests conformes

1. Objectif

Ce rapport documente l'exécution réelle de tests fonctionnels et de sécurité sur le module d'authentification de CYNÀ DEV : inscription, confirmation d'email, connexion, gestion des erreurs, rate-limiting, contrôle d'accès par rôle et réinitialisation de mot de passe.

2. Environnement de test

- Backend Node.js/Express démarré localement (node server.js), connecté à une base PostgreSQL 16 réelle initialisée avec le schéma exact du projet (sqlcyna.sql).
- Tests exécutés via des requêtes HTTP réelles (fetch) contre l'API en cours d'exécution — pas de simulation ni de mock.

Aucun serveur SMTP réel n'étant disponible dans cet environnement de test isolé, les tokens de confirmation d'email et de réinitialisation de mot de passe ont été injectés directement en base selon le même algorithme que le code de production (crypto.randomBytes(32) + SHA-256), afin de simuler la réception du lien par e-mail et de tester la logique réelle des endpoints concernés. Le code source de génération de token n'a pas été modifié.

3. Résultats détaillés

ID	Fonctionnalité testée	Comportement attendu	Résultat obtenu (réel)	Statut
T1. 1	Inscription — mot de passe fort	201 Created, compte créé, message de confirmation	201 — « Compte créé. Vérifiez vos emails pour confirmer votre inscription. »	OK
T1. 2	Inscription — mot de passe faible (« azerty »)	400, message de validation explicite	400 — « Le mot de passe doit contenir au moins 8 caractères, une majuscule, une minuscule, un chiffre et un caractère spécial »	OK
T1. 3	Inscription — email déjà utilisé	409 Conflict	409 — « Un compte existe déjà avec cet email »	OK
T1. 4	Connexion avant confirmation de l'email	Blocage explicite	403 — « Veuillez confirmer votre email avant de vous connecter »	OK
T1. 5	Confirmation de l'email avec token valide (24h)	200, compte activé	200 — « Email confirmé. Vous pouvez maintenant vous connecter. »	OK
T1. 5bis	Réutilisation du même token de confirmation	Rejet, token déjà consommé	400 — « Lien de confirmation invalide ou expiré »	OK
T1. 6	Connexion après confirmation, bon mot de passe	200, access_token renvoyé	200 — token JWT + profil utilisateur renvoyés	OK
T1. 7	Connexion avec un mauvais mot de passe	401 Unauthorized	401 — « Email ou mot de passe incorrect »	OK

ID	Fonctionnalité testée	Comportement attendu	Résultat obtenu (réel)	Statut
T1. 8	Rate-limiting sur /auth/login (11 tentatives en rafale)	Blocage HTTP 429 dans la fenêtre de 15 min (limite : 10 req/IP)	429 déclenché à la 8e tentative de la boucle — cohérent car 2 requêtes de connexion avaient déjà eu lieu juste avant dans la même fenêtre (10 requêtes cumulées au total)	OK
T1. 9	Accès à une route protégée sans token	401 Unauthorized	401 — « Authentification requise »	OK
T1. 10	Accès à une route protégée avec token valide	200, profil renvoyé	200 — profil complet renvoyé	OK
T1. 11	Accès à une route admin avec un compte CLIENT	403 Forbidden	403 — « Accès réservé aux administrateurs »	OK
T1. 12	Demande de réinitialisation de mot de passe	200, réponse neutre (anti-énumération)	200 — « Si cet email existe, vous recevrez un lien de réinitialisation. »	OK
T1. 13	Réinitialisation avec token valide (24h)	200 OK	200 — « Mot de passe réinitialisé. Vous pouvez vous connecter. »	OK
T1. 14	Connexion avec le nouveau mot de passe	200 OK	200 — connexion réussie avec le nouveau mot de passe	OK
T1. 15	Connexion avec l'ANCIEN mot de passe (doit être rejeté)	401 Unauthorized	401 — ancien mot de passe bien invalidé	OK

4. Synthèse

Indicateur	Valeur
Tests exécutés	16
Conformes (OK)	16
Non conformes (KO)	0
Taux de réussite	100 %

5. Constats notables

- Le rate-limiting (10 requêtes/15 min sur /auth/login, 5 requêtes/heure sur /auth/register) fonctionne exactement comme configuré dans le code (routes/auth.routes.js).
- La politique de mot de passe fort est appliquée systématiquement et le message d'erreur est explicite.
- Les tokens (confirmation, réinitialisation) sont à usage unique et stockés hachés (SHA-256) en base, jamais en clair — bonne pratique de sécurité confirmée.
- Le contrôle d'accès par rôle (CLIENT vs ADMIN) est correctement appliqué sur les routes protégées.

6. Conclusion

16 scénarios sur 16 se sont comportés exactement comme attendu, sans aucune anomalie de sécurité ou de logique métier détectée sur ce module. Le module d'authentification est jugé conforme et robuste.